

Lockdown

Scenario:

Suspicious outbound traffic from an IIS server: web-shell drop and connections to an unknown host

Examining:

- ➔ PCAP Capturing the initial traffic
- ➔ Full memory image of the server
- ➔ Malware sample recovered from disk(no idea what this means)

Reconstruct the Intrusion

PCAP Analysis – Wireshark

After flooding the IIS host with rapid-fire probes, the attacker reveals their origin. Which IP address generated this reconnaissance traffic?

- ➔ Statistics Conversations
- ➔ 6,007 packets sent between 10.0.2.4 to 10.0.2.15,-- different ports
- = 10.0.2.4

The attacker is carrying out targeted enumeration against the HTTP service on the IIS host. Based on the HTTP request headers, which tool is being used?

- ➔ Filtered for HTTP traffic
- ➔ Found a request that states: GET /nmaplowercheck1725947084
- = nmap

While reviewing the SMB traffic, you observe two consecutive Tree Connect requests that expose the first shares the intruder probes on the IIS host. Which two full UNC paths are accessed?

- ➔ UNC path: standard string format used in Windows to find things in local
- ➔ SMB tree connect request: access a specific shared folder or printer
- ➔ Googled how to filter by SMB tree requests: smb2.cmd == 3

= \\10.0.2.15\Documents, \\10.0.2.15\IPC\$

At this point, I understood that:

Attacker: 10.0.2.4

ISS Host: 10.0.2.15

Inside the share, the attacker plants a web-accessible payload that will grant remote code execution. What is the filename of the malicious file they uploaded?

- ➔ Google search: how to filter by SMB share edits in wireshark
- ➔ Smb2.cmd == 0x0009
- ➔ Found a single write request with the file shell.aspx
== shell.aspx

The newly planted shell calls back to the attacker over an uncommon but firewall-friendly port. Which listening port did the attacker use for the reverse shell

- ➔ Looked through the tcp requests following the HTTP GET request for the shell.aspx file.
- ➔ Found Numerous TCP streams between the hosts, on ports 49688 to 4443.
== 4443

Memory Dump Analysis

Kernel base: started address in system memory where kernel(OS core program) is loaded – Kernel: bridge between hardware and software

Your memory snapshot captures the system's kernel in situ(means exact replica), providing vital context for the breach. What is the kernel base address in the dump?

- ➔ Volatility: used to open and analyze a raw memory dump
- ➔ Had to install volatility 3 on my kali linux
- ➔ python3 vol.py -f memdump.mem windows.info
== 0xf80079213000

A trusted service launches an unfamiliar executable residing outside the usual IIS stack, signaling a persistence implant. What is the final full on-disk path of that executable?

Any Executable placed in the StartUp directory automatically runs when a user logs into windows → attackers routinely place malicious files here to establish persistence

Google Search: python3 vol.py -f memdump.mem windows.pstree

→ shows which process started which process

→ Asterisks(*) represents branches of the tree(more/deeper) branches == suspicious)

```
** 2452 628      svchost.exe      0xce06571cb280  15      -      0
False          2024-09-10      05:30:04.000000  UTC      N/A
\Device\HarddiskVolume1\Windows\System32\svchost.exe
C:\Windows\system32\svchost.exe      -k      iissvcs
C:\Windows\system32\svchost.exe

*** 4332      2452      w3wp.exe      0xce06574ca080  0      -      0
False  2024-09-10 05:44:45.000000 UTC  2024-09-10 06:10:48.000000 UTC
\Device\HarddiskVolume1\Windows\System32\inet_srv\w3wp.exe      -      -

**** 900      4332      updatenow.exe  0xce0657ddb1c0  3      -      0
True          2024-09-10      06:08:23.000000  UTC      N/A
\Device\HarddiskVolume1\ProgramData\Microsoft\Windows\Start
Menu\Programs\Startup\updatenow.exe  "C:\ProgramData\Microsoft\Windows\Start
Menu\Programs\Startup\updatenow.exe"
C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\updatenow.exe
```

→ Shows how a trusted service(svchost) launched a web worker engine(w3wp), which is responsible for serving web traffic and running web application code. Instead of processing web pages updatenow.exe is spawned.

→ Updatenow.exe is spawned inside the StartUp directory = persistence

==C:\ProgramData\Microsoft\Windows\Start
Menu\Programs\Startup\updatenow.exe

The reverse shell's outbound traffic is handled by a built-in Windows process that also spawns the implanted executable. What is the name of this process, and what PID does it run under?

→ w3wp.exe spawned the implanted executable, as seen in the pstree command previously

== w3wp.exe, 4332

Malware Sample Analysis

Static inspection reveals the binary has been packed to hinder analysis. Which packer was used to obfuscate it?

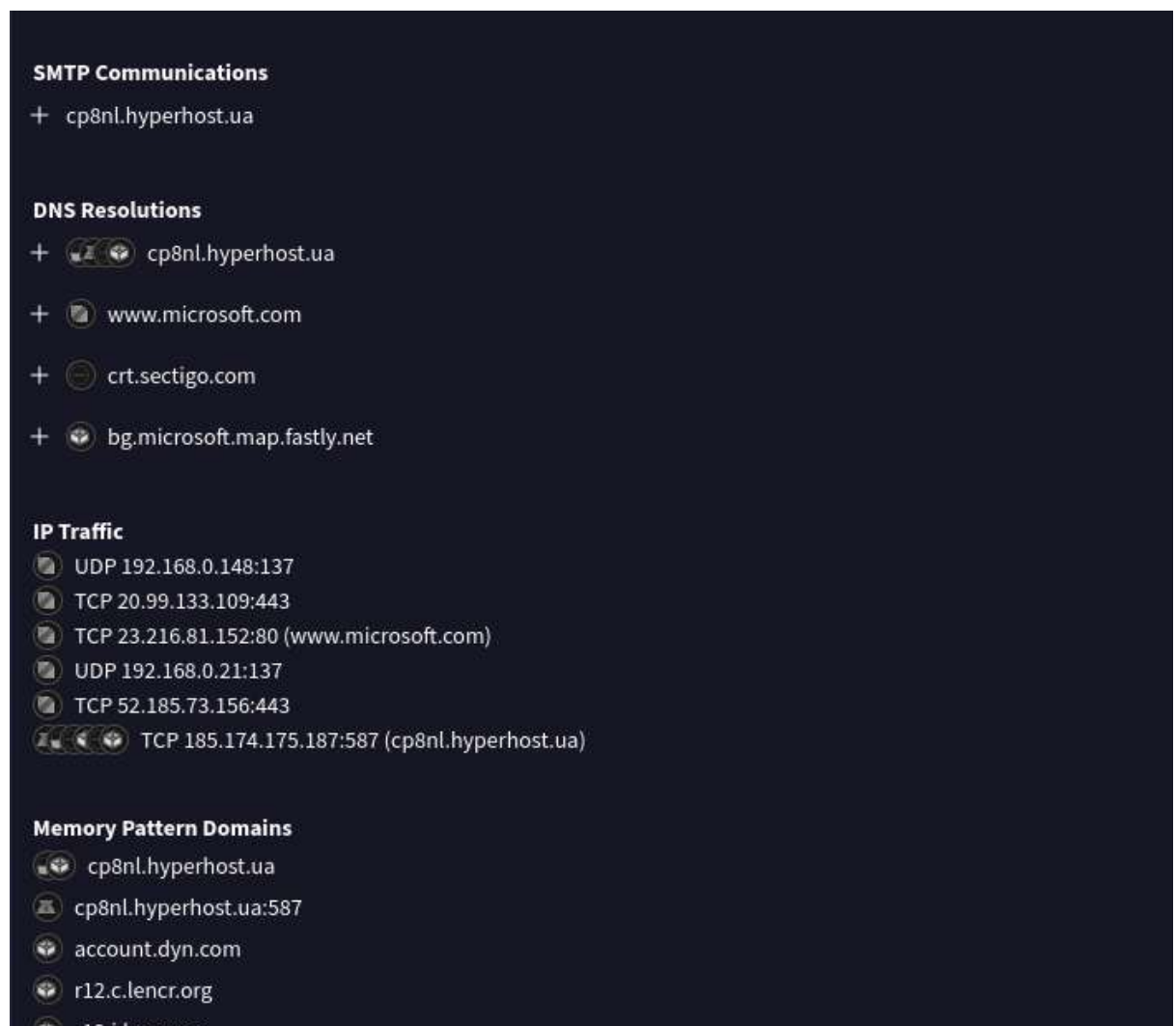
→ Uploaded the updatenow.exe file onto virustotal(just a browser, no download needed thank goodness)

== UPX

Threat-intel analysis shows the malware beaconing to its command-and-control host. Which fully qualified domain name (FQDN) does it contact?

→ Looking at the behavior section of virustotal analysis

== cp8nl.hyperhost.ua



Open-source intel associates that hash with a well-known commodity RAT. To which malware family does the sample belong?

- ➔ RAT = Remote Access Trojan
- ➔ Hash: c25a6673a24d169de1bb399d226c12cdc666e0fa534149fc9fa7896ee61d406f
- ➔ Google searched the malware family for the hash

== Agent tesla

NOW: Fully reconstruct the intrusion

- ➔ Attacker(10.0.2.4) started by scanning the target network through nmap
- ➔ Scanned different ports to figure out a IIS server and SMB
- ➔ Attacker tried to access shared folders on the IIS server
- ➔ Found a place and uploaded a 'web shell'(allows attacker to type commands into a web browser) shell.aspx file into a web-accessible directory
- ➔ Once uploaded the attacker triggered a GET request through their browser and the web server process(w3wp.exe) thus processed that page and ultimately processed shell.aspx which opened a connection back to the attacker on port 4443 → reverse shell
- ➔ To establish persistence, the attacker used the reverse shell to download updatenow.exe(a compressed version with UPX, to hide strings from basic antivirus scanners) onto the disk, inside the StartUp folder in Windows
- ➔ Now updatenow.exe 'wakes up' every reboot, connects to the domain cp8nl.hyperhost.ua and dumps all the data its stolen, such as credentials, keystroke logs, and other stolen data inside normal-looking traffic(HTTP/HTTPS post, DNS SMTP(Email)). – Agent Tesla Family

Takeaways:

- **Google search is important**
- **Wireshark: how the attacker recon, exploit and connect to the target(.pcap)**
- **Volatility: gap between network traffic and what actually happened in the RAM(.mem: RAM dump)**

Windows.pstree: execution tree(parent-child hierarchy of processes)

Windows.netscan: historical/active network connections

- ➔ **Execution threat and persistence mechanism inside**

- **Virustotal: analyzes the actual malicious file**

Gotta be able to use these tools well, even the tools you've never seen before; gotta be able to adapt quickly through research.

Learn to put things together. Findings from various tools into a single intrusion cycle.

This is fun!